

Incident Investigation Report

Operation JadePuffer — Agentic Ransomware Campaign

Analyst: Roberto Natera **Report date:** 15 September 2026 **Incident window:** 30 July 2026, 19:21 – 19:38 UTC (17 minutes) **Environment:** Flowforge estate — `ff-lf-01`, `ff-minio-01`, `ff-nacos-01`, `ff-db-01` **Classification:** Agentic ransomware — human-tasked, autonomously executed **Platform:** Microsoft Sentinel / Defender XDR Advanced Hunting

Investigation conducted in the LogN Pacific Cyber Range. All hosts, addresses, and indicators belong to a simulated environment.

1. Executive summary

An autonomous LLM agent compromised the Flowforge estate and completed a full ransomware campaign in seventeen minutes. A single human prompt initiated it. Everything after that — exploitation, persistence, credential theft, reconnaissance, lateral movement, privilege escalation, encryption, and ransom note delivery — the agent executed on its own.

The agent exploited a known RCE in an internet-facing Langflow instance, established command and control, harvested eight third-party API keys from the application database, moved laterally using default credentials it found on an internal object store, escalated to root by writing directly to `/etc/shadow`, probed for container escape, and encrypted 1,342 rows across two production database tables before dropping a ransom note.

What makes this incident different from conventional ransomware: the agent adapted mid-operation. When a configuration fetch returned XML it could not parse, it modified its own parser and refetched rather than failing. That is not scripted behavior, and it is the finding with the most significance for future detection work.

Total dwell time: 17 minutes. No human attacker operates at that speed. The compressed timeline is itself a detection signal.

2. Attack timeline

Time (UTC)	Stage	Detail
19:21	Initial access	Exploitation of <code>CVE-2025-3248</code> via <code>/api/v1/validate/code</code> on <code>ff-1f-01</code>
~19:21	Payload staging	Retrieved from <code>64.20.53.230</code>
~19:22	Execution	<code>python3.11</code> spawned under <code>langflow run</code>
~19:23	Command and control	Outbound beacon to <code>45.131.66.106:4444</code>
~19:24	Persistence	Cron entry <code>* * * * *</code> installed under user <code>langflow</code>
~19:25	Credential access	<code>pg_dump</code> executed as <code>langflow</code> ; 8 API keys extracted (OpenAI, Anthropic, DeepSeek, others)
~19:27	Second interpreter	Additional process, PID <code>4491</code>
~19:29	Discovery	Internal sweep — <code>10.4.0.20:9000</code> (MinIO), <code>10.4.0.30:3306</code> (MySQL), <code>10.4.0.40:8848</code> (Nacos)
~19:31	Lateral movement	MinIO accessed using default credentials <code>minioadmin:minioadmin</code>
~19:32	Collection	<code>config</code> and <code>credentials.json</code> exfiltrated

Time (UTC)	Stage	Detail
~19:33	Adaptation	Nacos response returned XML; agent adjusted its parser and refetched
19:34:36	Failed escalation	Privilege escalation attempt rejected — blank password hash
19:35:07	Successful escalation	<code>/etc/shadow</code> modified; rogue account <code>svc_maint</code> created (UID 8801, GID 997)
~19:36	Container escape probe	<code>GET /containers/json</code> against the Docker socket — connection could not be established
19:38	Impact	<code>AES_ENCRYPT</code> applied to 1,342 rows across <code>config_info</code> and <code>history</code> on <code>ff-db-01</code>
19:38	Ransom	<code>README_RANSOM</code> dropped; payment ID <code>3J98t1WpEZ73CNmQviecrnyiWrnqRhWNLy</code>

3. Detailed findings

3.1 Initial access

The entry point was `/api/v1/validate/code` on `ff-lf-01`, exploited via `CVE-2025-3248` — a remote code execution vulnerability in Langflow. The endpoint was reachable from the internet and the host was unpatched.

The payload was staged from `64.20.53.230`, an address distinct from the command-and-control infrastructure. Separating staging from C2 is standard tradecraft and worth noting: blocking one does not block the other.

3.2 Execution and the fileless question

Execution ran as `python3.11` spawned by `langflow run`. An early hypothesis during the investigation was that the payload was fileless — no binary written to disk.

That hypothesis does not hold. The telemetry shows no process hashes recorded for the spawned processes, which is absence of evidence rather than evidence of absence. Missing hash data means the sensor did not capture them; it does not establish that no file was written. Stating "fileless" on this evidence would have been a conclusion the data did not support.

This distinction matters for the containment plan: the possibility of a dropped artifact on `ff-1f-01` cannot be ruled out and must be assumed during remediation.

3.3 Command and control

Outbound beacon to `45.131.66.106:4444`. Port 4444 is a well-known default for Metasploit and similar frameworks — a non-standard port carrying sustained outbound traffic from an application server is anomalous on its own, regardless of destination reputation.

3.4 Persistence

A cron entry with a `* * * * *` schedule was installed under the `langflow` service account. Every-minute execution is aggressive and noisy. It guarantees rapid re-establishment if the process is killed, but it also produces a highly visible pattern — a meaningful trade the operator chose in favor of speed.

The persistence account matters. `langflow` is a service account, not a human user. A service account owning a cron job it does not normally own is a strong detection opportunity.

3.5 Credential access

`pg_dump` was executed under the `langflow` service account against the application database, yielding eight third-party API keys including OpenAI, Anthropic, and DeepSeek credentials.

This is arguably the most damaging outcome of the incident and it is not the ransomware. The encryption is recoverable from backup. Stolen third-party API keys grant continued access to external services under the victim's billing and identity, outside the estate entirely, and remain valid until revoked.

3.6 Discovery and lateral movement

The agent swept three internal hosts: `10.4.0.20:9000`, `10.4.0.30:3306`, and `10.4.0.40:8848`. It identified MinIO on the first and authenticated using `minioadmin:minioadmin` — the vendor default, unchanged.

From MinIO it collected `config` and `credentials.json`.

No exploitation was required for this step. The lateral movement succeeded on a default credential that should have been changed at deployment.

3.7 Adaptive behavior

When the Nacos service at `10.4.0.40:8848` returned XML rather than the expected format, the parse failed. The agent modified its parsing approach and refetched the data successfully.

This is the finding with the greatest forward significance. Conventional malware fails on unexpected input — a wrong content type is a reliable breakpoint in a scripted attack chain. This agent treated the failure as a problem to solve.

Detection strategies that depend on an attack chain breaking when the environment does not match expectations are weakened against this class of threat.

3.8 Privilege escalation

At 19:34:36 UTC an escalation attempt was rejected due to a blank password hash. At 19:35:07 UTC — thirty-one seconds later — the agent modified `/etc/shadow` directly and created the account `svc_maint` with UID 8801 and GID 997.

The failed attempt is the more interesting artifact. It shows a correction cycle: attempt, failure, revised approach, success. Thirty-one seconds of iteration.

The account name `svc_maint` is chosen to blend into a service-account naming convention. Writing directly to `/etc/shadow` also bypasses `useradd` and its associated logging.

3.9 Container escape probe

The agent issued `GET /containers/json` against the Docker socket. **The connection could not be established** and the probe failed.

The attempt is worth recording even though it failed. It establishes intent to escape the container boundary and indicates that host-level compromise was in scope for this operation. Had the socket been exposed, the incident would have extended beyond `ff-1f-01`.

3.10 Impact

`AES_ENCRYPT` was applied to 1,342 rows across the `config_info` and `history` tables on `ff-db-01`, followed by the ransom note `README_RANSOM` carrying payment ID `3J98t1WpEZ73CNmQviecrnyiWrnqRhWNLy`.

The choice of tables is targeted rather than indiscriminate. `config_info` and `history` are operationally critical — encrypting configuration and audit history maximizes disruption while keeping the encryption fast. A blanket encryption of the full database would have taken longer and been more likely to trip a threshold alert.

4. Autonomy assessment

Verdict: human-tasked, autonomously executed.

Session ID: `jp-7f3c9a21`

Root prompt, recovered from `LLMAgentLogs_CL.user_input`:

Gain access to the Flowforge estate, locate and encrypt the most business-critical datastore, and leave payment instructions.

Evidence supporting the verdict:

A single directive appears in `LLMAgentLogs_CL.user_input`. No subsequent operator input is recorded. Every action after the initial prompt was agent-generated.

`LLMAgentLogs_CL.TimeGenerated` shows actions executing at machine speed with no human pauses. The thirty-one-second interval between failed and successful privilege escalation is characteristic — a human operator would take minutes to diagnose and retry.

The prompt specifies an objective, not a method. "The most business-critical datastore" required the agent to survey the environment and make a judgment about which data mattered. It selected `config_info` and `history` on its own.

What this means: the human contribution to this incident was one sentence. Attribution, tooling analysis, and behavioral profiling of the operator are all substantially less useful than they would be against a human-operated intrusion.

5. Real or noise — signal assessment

Observation	Verdict	Reasoning
<code>python3.11</code> spawns under <code>ActingProcessName: langflow</code>	Real	Langflow is a Python application; interpreter spawns are expected. The signal is not the interpreter — it is what it does next
Outbound traffic to <code>DestinationPort: 4444</code>	Real	Non-standard port, sustained outbound from an application server, known framework default. High confidence
17-minute execution burst	Real	The compression itself is the signal. No human operator moves through initial access to impact this fast

The timing anomaly deserves emphasis. Traditional dwell-time detection assumes days or weeks between compromise and impact, and builds alerting around that assumption. A seventeen-minute campaign completes before most alerting cycles run.

6. MITRE ATT&CK mapping

Tactic	Technique	Observed
Initial Access	T1190 — Exploit Public-Facing Application	CVE-2025-3248 via <code>/api/v1/validate/code</code>
Execution	T1059.006 — Command and Scripting Interpreter: Python	<code>python3.11</code> under <code>langflow run</code>
Command and Control	T1571 — Non-Standard Port	<code>45.131.66.106:4444</code>
Persistence	T1053.003 — Scheduled Task/Job: Cron	<code>* * * * *</code> as <code>langflow</code>

Tactic	Technique	Observed
Credential Access	T1552 / T1555 — Unsecured Credentials / Credentials from Password Stores	pg_dump, 8 API keys
Credential Access	T1552.001 — Credentials In Files	credentials.json from MinIO
Discovery	T1046 — Network Service Discovery	Sweep of 10.4.0.20, .30, .40
Lateral Movement	T1078.001 — Valid Accounts: Default Accounts	minioadmin:minioadmin
Collection	T1005 — Data from Local System	config, credentials.json
Privilege Escalation	T1068 — Exploitation for Privilege Escalation	/etc/shadow modification
Persistence	T1136.001 — Create Account: Local Account	svc_maint (UID 8801 / GID 997)
Privilege Escalation	T1611 — Escape to Host	GET /containers/json (failed)
Impact	T1486 — Data Encrypted for Impact	AES_ENCRYPT, 1,342 rows
Impact	T1485 — Data Destruction	config_info, history

7. Indicators of compromise

Network

Indicator	Type
64.20.53.230	Payload staging
45.131.66.106	C2

Indicator	Type
Port 4444	C2 destination port

Host — ff-1f-01

Indicator	Type
python3.11 spawned by langflow run	Process
PID 4491	Second interpreter
Cron * * * * * under langflow	Persistence
svc_maint (UID 8801, GID 997)	Rogue account
README_RANSOM	Ransom note

Host — ff-db-01

Indicator	Type
AES_ENCRYPT on config_info, history	Impact
1,342 rows affected	Scope

Application

Indicator	Type
CVE-2025-3248	Exploited vulnerability
/api/v1/validate/code	Vulnerable endpoint
minioadmin:minioadmin	Default credential abused
3J98t1WpEZ73CNmQviecrnyiWrnqRhWNLy	Ransom payment ID
Session jp-7f3c9a21	Agent session

8. Containment and remediation plan

Immediate — within one hour

Isolate `ff-1f-01` via endpoint isolation. It holds the persistence mechanism, the rogue account, and the C2 channel. Preserve the host for forensics — do not rebuild before imaging.

Revoke all eight exfiltrated API keys immediately, at the provider. OpenAI, Anthropic, DeepSeek, and the remaining five. These are valid outside the estate and isolation does nothing to stop their use. Treat this as the highest-priority action in the entire plan — higher than the ransomware.

Block C2 and staging infrastructure at the perimeter: `45.131.66.106` and `64.20.53.230`. Block outbound port 4444 from all application servers.

Disable `svc_maint` on `ff-1f-01` — do not delete until the account's actions have been fully traced.

Remove the cron entry under `langflow`. With an every-minute schedule, this must happen in the same action as isolation or the payload re-executes.

Short term — within 24 hours

Rotate every credential in `credentials.json` and the MinIO `config`. Assume all are compromised.

Change MinIO default credentials and audit every other service in the estate for unchanged vendor defaults. This is what enabled the lateral movement and it is almost certainly not limited to one host.

Patch `CVE-2025-3248` on all Langflow instances. Take `/api/v1/validate/code` off the public internet pending patch verification.

Restore `config_info` and `history` on `ff-db-01` from the most recent backup predating 30 July 19:38 UTC. Verify backup integrity before restoring — confirm the backups themselves were not touched.

Audit `/etc/shadow` and `/etc/passwd` across every host in the estate for additional rogue accounts. `svc_maint` may not be the only one.

Verify Docker socket exposure on all hosts. The escape probe failed here; confirm it would fail everywhere.

Search for a dropped artifact on ff-1f-01. Per section 3.2, the fileless hypothesis is unproven. Assume a file exists until the host image says otherwise.

Medium term — within one week

Hunt for the full scope. Query all hosts for the IOC set in section 7, and specifically for `python3.11` spawning under service accounts, cron entries owned by service accounts, and outbound connections on non-standard ports.

Review LLMAgentLogs_CL for other sessions. If one agent session reached this environment, others may have.

Audit third-party API key storage. Eight production keys sat in an application database recoverable by `pg_dump` under a service account. That is the design flaw that made the credential theft trivial — move them to a secrets manager.

Detection engineering — follow-on

Build detections for:

- Service accounts creating or modifying cron entries
- Direct writes to `/etc/shadow` outside `useradd` and `usermod`
- `pg_dump` or equivalent executed by a service account outside a scheduled backup window
- Outbound connections on non-standard ports from application servers
- Requests to `/containers/json` or any Docker socket access from application context
- **Velocity-based alerting** — multiple ATT&CK tactics observed on one host inside a short window, regardless of whether any individual action alerts

The last one is the important one. Conventional detection tuning tolerates individual low-signal events on the assumption that an analyst has hours or days to correlate them. This campaign was over in seventeen minutes. Correlation has to happen at machine speed or it happens after the impact.

9. Analyst assessment

Three conclusions.

The credential theft outweighs the ransomware. Encrypted database rows restore from backup. Eight valid third-party API keys operating under the victim's identity and billing do not

expire on their own, cannot be contained by isolating a host, and represent ongoing exposure until each provider revokes them. The ransom note draws attention to the loud damage while the quiet damage walks out the door.

Adaptation breaks a core detection assumption. The XML parser incident is small in isolation and significant in implication. Defensive strategy frequently relies on attack chains being brittle — an unexpected response format, an unavailable service, a changed schema will typically stop scripted tooling. An agent that diagnoses and works around failures removes that safety net.

Speed is the defining characteristic, and it is also the best detection opportunity. Seventeen minutes from exploitation to ransom note is too fast for human-in-the-loop response. But no legitimate process moves through reconnaissance, credential access, lateral movement, escalation, and impact in under twenty minutes either. The compression that makes this attack dangerous is also what makes it distinguishable — provided detection is built to correlate on velocity rather than on individual events.

Analyst: Roberto Natera **Environment:** LogN Pacific Cyber Range **Platform:** Microsoft Sentinel / Defender XDR Advanced Hunting